

Website Security Audit Report

Report Release Date	April 2, 2026
Type of Audit	Website Security Audit
Type of Audit Report	Follow up Audit Report
Period	December 23, 2025 to March 20, 2026

AAA Technologies Ltd

278-280, F Wing, Solaris-1,
Saki Vihar Road, Opp. L & T Gate No. 6,
Powai, Andheri (East),
Mumbai 400 072, INDIA
Tel: + 91 22 28573815 / 16
Fax: + 91 22 40152501
info@aaatechnologies.co.in
www.aaatechnologies.co.in



Document Control

Document Preparation	
Document Title	Website Security Audit Report
Document ID	AAA/WAC/2026153
Document Version	1.0
Prepared by	Lalit Kumar
Reviewed by	Bharati Vane
Approved by	Venugopal M. Dhoot
Released by	Venugopal M. Dhoot
Release Date	April 2, 2026

Document Change History		
Version	Date	Remarks / Reason of change
1.0	April 2, 2026	Final Report to be submitted to NIC

Document Distribution List			
Name	Organization	Designation	Email ID
Neha Thakur	AAA Technologies Limited	Information Security Consultant	neha2@aaatechnologies.co.in
Bharati Vane	AAA Technologies Limited	Information Security Manager	bharati@aaatechnologies.co.in
Venugopal M. Dhoot	AAA Technologies Limited	Managing Director	vmdhoot@aaatechnologies.co.in
Navinder Sharma	NIC	Scientist-C	navinder.sharma@nic.in
Pravesh Kumar	NIC	Developer	pravesh8822@gmail.com

Table of Contents

1	Introduction	4
2	Engagement Scope.....	5
3	Details of Auditing Team.....	6
4	Audit Activities and Timelines.....	7
5	Audit Methodology and Criteria / Standard referred for audit	8
6	Tools / Software used	9
7	Executive Summary.....	10
7.1	Graphical representation of Vulnerabilities.....	10
7.2	Summary of Vulnerabilities.....	11
7.3	Summary of Significant Findings and Recommendations.....	12
8	Detailed Observations.....	18
9	Appendices.....	43

1 Introduction

AAA Technologies Limited ('AAA') was engaged by Department of Labour, Government of Punjab to perform website security audit of Department of Labour, Government of Punjab. The report highlights gaps identified and recommendations to remediate the gaps.

Objective

The objectives of audit were to provide independent evaluation of the status of controls of Department of Labour, Government of Punjab. The main purpose of the test is to determine any security vulnerabilities in the website as specified in the scope.

Disclaimers and Restrictions

- Organisation's management is responsible for its assertions. Our responsibility is to express an opinion on management's assertion based on our audit.
- The audit was conducted in accordance with the Information Systems Auditing Standards issued by the Standards Board of Information Systems Audit and Control Association. Further, the objective of the audit was to obtain reasonable assurance that the assertion is not materially misstated. Our audit included (1) Obtaining an understanding of the objectives; (2) selectively testing these objectives; (3) testing and evaluating; and (4) performing such other procedures as we considered necessary under the circumstances. We believe that our audit provides a reasonable basis for our opinion.
- Because of inherent limitations in controls, errors or fraud may occur and may not be detected. Furthermore, the projection of any conclusions, based on our findings, to future periods is subject to the risk that (1) changes made to the system or controls, (2) changes in processing requirements, (3) changes required because of the passage of time, or (4) degree of compliance with the policies or procedures may alter the validity of such conclusions.
- This report is strictly to be used for the intend purpose of compiling the controls being followed for the purposes of analysis and improvement.
- It is firmly recommended to test out all our technical recommendations to the system internals such as services or registry in a test environment and the impact on the reliability and integrity of the system be evaluated before rolling out the changes to the production environment.
- This report does not include any representation on the financial, marketing, human resources or any other health of the Organisation or on the future viability of the Organisation or minimizing or exposure of all risks associated with computerized environment, due to its inherent limitations.

2 Engagement Scope

S. No.	Asset Description	Criticality of Asset	Internal IP Address	URL	Public IP Address	Location	Hash Value (in case of Applications)	Version (in case of Applications)	Other details such as make and model in case of network devices or security devices.
1)	Website / Web Application	High	10.44.25.66	https://pblabour.gov.in/ePortalstg/	103.118.160.157	Delhi	SHA-256 : F6ED83669AD2FBCCB3A0CD797DFD68AC43914DFE57BE2E945A0EB80A384E89CF , MD5 : 2CAB6AE8FF8F4C1853547F50B6863AA7	NA	NA

3 Details of Auditing Team

S. No	Name	Designation	Email ID	Professional Qualifications/ Certifications	Whether the resource has been listed in the Snapshot information published on CERT-In's website(Yes/ No)
1)	Venugopal M. Dhoot	Managing Director	vmdhoot@aaatechnologies.co.in	B.Com(Hons), LLb, FCA, DISA, DIRM, CEH	Yes
2)	Bharati Vane	Information Security Manager	bharati@aaatechnologies.co.in	BSC, CEH, CISA (USA)	Yes
3)	Neha Thakur	Information Security Consultant	neha2@aaatechnologies.co.in	CEH	YES

4 Audit Activities and Timelines

Audit Phases	Timelines
Receipt of URL / Application from Auditee for Audit	December 23, 2025
Execution of Assignment	December 23, 2025 to March 20, 2026
Report Preparation	March 20, 2026
Report Submission to Auditee	April 2, 2026

5 Audit Methodology and Criteria / Standard referred for audit

During the course of this review, we assessed the activities as stated above for compliance with CERT-In Guidelines, OWASP & other known vulnerabilities and best practices, as applicable.

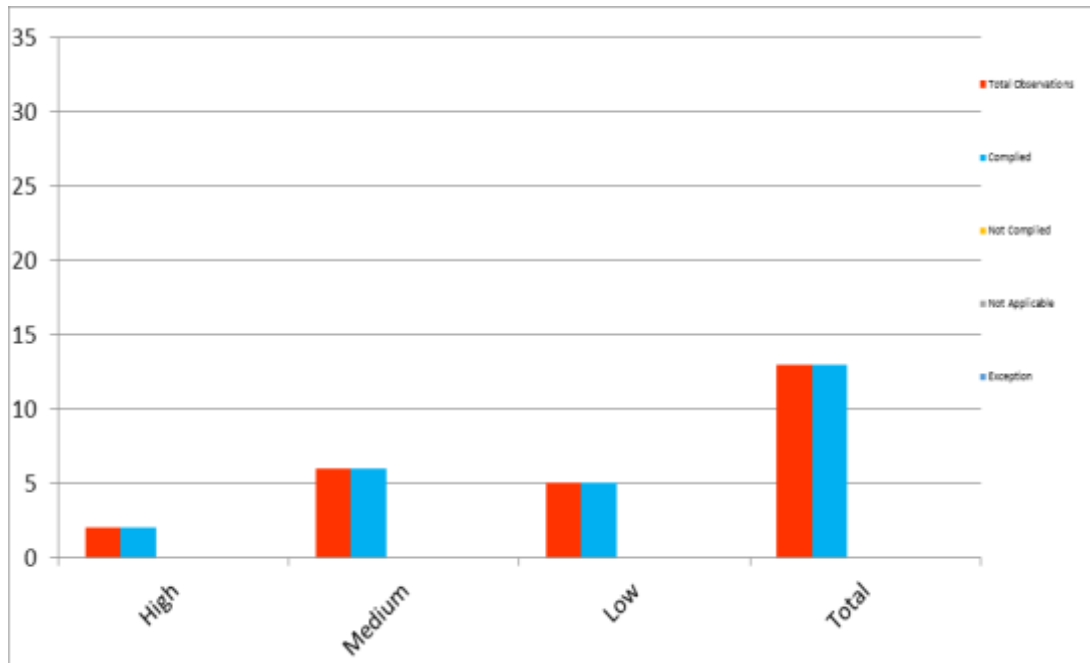
We conducted the assignment using automated tools and conducting manual testing, as applicable.

6 Tools / Software used

S. No.	Name of Tool/Software used	Version of the tool /Software used	Open Source/Licensed
1)	Invicti Professional (formerly Netsparker)	v25.10.1	Licensed
2)	Burp Suite Professional	2025.1	Licensed

7 Executive Summary

7.1 Graphical representation of Vulnerabilities



7.2 Summary of Vulnerabilities

Activities	Total Observations	Complied	Not Complied	Exception	Not Applicable
Website Security Audit	13	13	0	0	0

7.3 Summary of Significant Findings and Recommendations

S. No.	Affected Asset i.e. IP / URL / Application etc	Observation / Vulnerability Title	CVE / CWE	Severity	Recommendations	Reference	New or Repeat Observation
1)	https://pblabour.gov.in/ePortalstg/	Out-of-Date Version of jQuery	CWE-1104	High	It is recommended to update to latest/stable version.	Owasp & Cert-in guidelines	New
2)	https://pblabour.gov.in/ePortalstg/	Malicious file upload	CWE-434	High	Following things should be implemented in file upload module: 1 Inspect the content of uploaded files, and enforce a white list of accepted, non-executable content types. Additionally, enforce a blacklist of common executable formats, to hinder hybrid file attacks. 2 Enforce a white list of accepted, non-executable file extensions. 3 If uploaded files are downloaded by users, supply an accurate non-generic Content-type header, and also a Content-	Owasp & Cert-in guidelines	New

					disposition header which specifies that browsers should handle the file as an attachment. 4 Enforce a size limit on uploaded files (max 8-10 MB); this can be implemented both within application code and in the web server's configuration. 5 Reject attempts to upload archive formats such as ZIP. 6 Multiple file extension like test.pdf.txt.php.jif.jpg should not be allowed for upload. 7 Proper checks to be put on Content type and MIME type as well.		
3)	https://pblabour.gov.in/ePortalstg/	Error Page Found	CWE-1104	Medium	It is recommended to implement custom error on the web application	Owasp & Cert-in guidelines	New
4)	https://pblabour.gov.in/ePortalstg/	Session Timeout not implemented	CWE-1104	Medium	Application should terminate a session if there is no activity from the user-side for a fixed period of time, e.g., 15 minutes.	Owasp & Cert-in guidelines	New

5)	https://pblabour.gov.in/ePortalstg/	Web Server Information Disclosure	CWE-693	Medium	Server version should not be displayed to the end user.	Owasp & Cert-in guidelines	New
6)	https://pblabour.gov.in/ePortalstg/	Cookie without Same Site Attribute	CWE-749	Medium	The server can set a same-site cookie by adding the SameSite=... attribute to the Set-Cookie header. There are three possible values for the SameSite attribute: • Lax: In this mode, the cookie will only be sent with a top-level get request. Set-Cookie: key=value; SameSite=Lax • Strict: In this mode, the cookie will not be sent with any cross-site usage even if the user follows a link to another website. Set-Cookie: key=value; SameSite=Strict • None: In this mode, the cookie will be sent with the cross-site requests. Cookies with	Owasp & Cert-in guidelines	New

					SameSite=None must also specify the Secure attribute to transfer them via a secure context. Setting a SameSite=None cookie without the Secure attribute will be rejected by the browsers. Set-Cookie: key=value; SameSite=None; Secure		
7)	https://pblabour.gov.in/ePortalstg/	Internal server error	CWE-1021	Medium	Analyze this issue and review the application code in order to handle unexpected errors; this should be a generic practice, which does not disclose further information upon an error. All errors should be handled server-side only.	Owasp & Cert-in guidelines	New
8)	https://pblabour.gov.in/ePortalstg/	Cross-Origin resource sharing misconfiguration	CWE-693	Medium	Rather than using a wildcard or programmatically verifying supplied origins, use a whitelist of trusted domains.	Owasp & Cert-in guidelines	New
9)	https://pblabour.gov.in/ePortalstg/	HTTP Security	CWE-	Low	It is recommended to implement	Owasp & Cert-in	New

	ortalstg/	Headers Not Implemented	1275		security headers to provide additional layer of security in application such as Content Security policy.	guidelines	
10)	https://pblabour.gov.in/ePortalstg/	HTTP Dangerous Method Enabled	CWE-275	Low	It is recommended to disable http dangerous methods on the web server	Owasp & Cert-in guidelines	New
11)	https://pblabour.gov.in/ePortalstg/	Email Address Disclosure	CWE-749	Low	Use generic email addresses such as contact@ or info@ for general Communications and remove user/people specific email addresses from the website; should this be required, use submission forms for this purpose.	Owasp & Cert-in guidelines	New
12)	https://pblabour.gov.in/ePortalstg/	Input Validation not implemented properly in the application	CWE-20	Low	It is recommended that Username and Password fields should be validated at client and server end and it should not be null.	Owasp & Cert-in guidelines	New
13)	https://pblabour.gov.in/eP	Buffer overflow	CWE-119	Low	Length restrictions for every input field should be	Owasp & Cert-in	New

	ortalstg/				defined at client as well as at server end.	guidelines	
--	-----------	--	--	--	---	------------	--

For AAA Technologies Limited

Venugopal M. Dhoot

Managing Director

B.Com(Hons), LLb, FCA, DISA, DIRM, CEH

Place: Mumbai

Dated: April 2, 2026

8 Detailed Observations

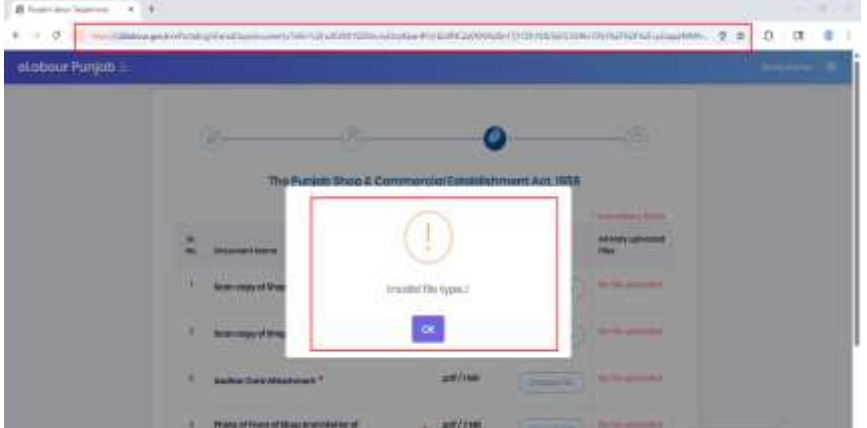
1)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Out-of-Date Version of jQuery
iii.	Detailed Observation / Vulnerable Point	It was observed that this page is using a outdated version of jQuery (1.12.4).
iv.	CVE / CWE	CWE-1104
v.	Severity	High
vi.	Recommendation	It is recommended to update to latest version 3.7.1 of jQuery.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence: 
x.	Status	Complied



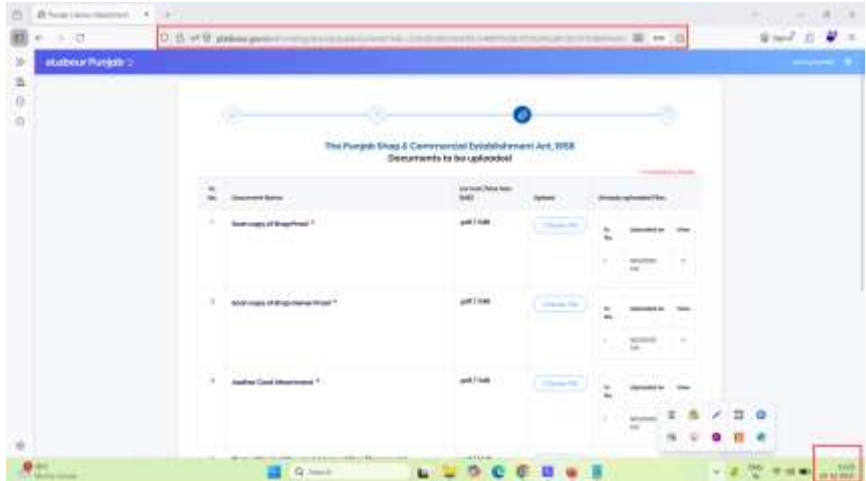
2)

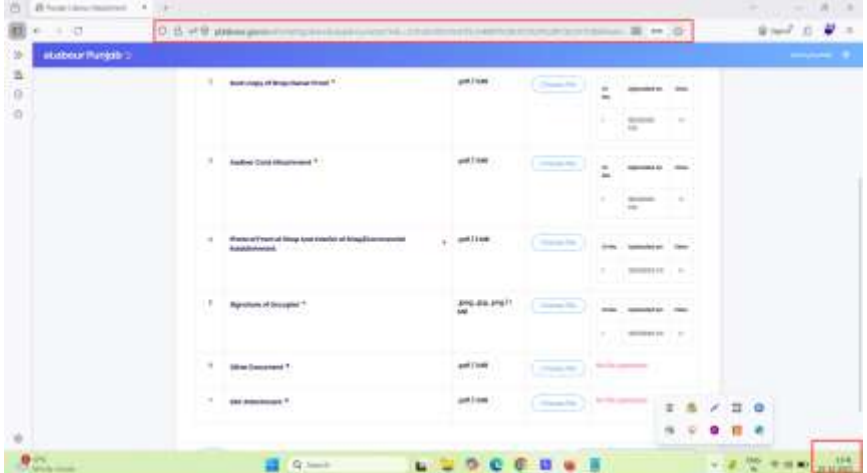
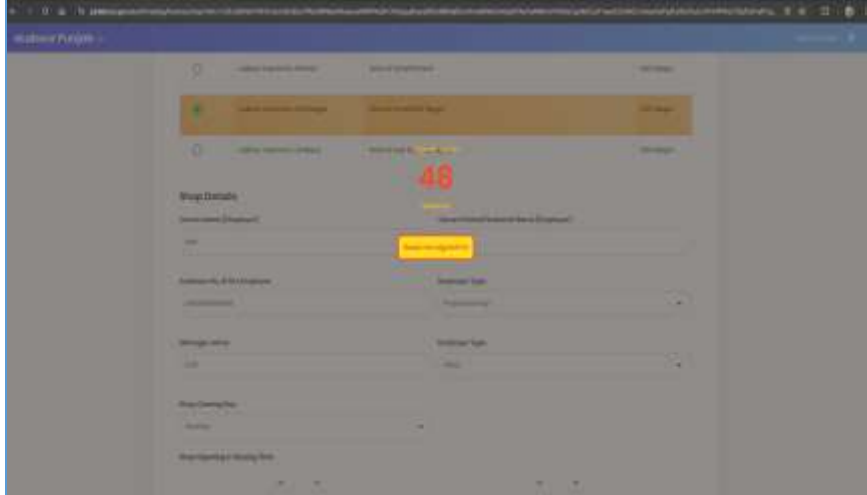
i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Malicious File Upload
iii.	Detailed Observation / Vulnerable Point	It was observed that malicious file upload is possible in the application.
iv.	CVE / CWE	CWE-1104
v.	Severity	High
vi.	Recommendation	Following things should be implemented in file upload module: 1 Inspect the content of uploaded files, and enforce a white list of accepted, non-executable content types. Additionally, enforce a blacklist of common executable formats, to hinder hybrid file attacks. 2 Enforce a white list of accepted, non-executable file extensions. 3 If uploaded files are downloaded by users, supply an accurate non-generic Content-type header, and also a Content-disposition header which specifies that browsers should handle the file as an attachment. 4 Enforce a size limit on uploaded files (max 8-10 MB); this can be implemented both within application code and in the web server's configuration. 5 Reject attempts to upload archive formats such as ZIP. 6 Multiple file extension like test.pdf.txt.php.jif.jpg should not be allowed for upload. 7 Proper checks to be put on Content type and MIME type as well.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:

		 Final Compliance report Evidence: 
x.	Status	Complied

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Custom Error Page not implemented
iii.	Detailed Observation / Vulnerable Point	It was observed that this page contains an error message that may disclose sensitive information.
iv.	CVE / CWE	CWE-614
v.	Severity	Medium
vi.	Recommendation	It is recommended to implement custom error page on web application
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence: 
x.	Status	Complied

4)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Session Timeout not implemented
iii.	Detailed Observation / Vulnerable Point	It was observed that an email address disclosure. It was observed that even if the Browser is logged in and idle it does not logout the session automatically.
iv.	CVE / CWE	CWE-1275
v.	Severity	Low
vi.	Recommendation	Application should terminate a session if there is no activity from the user-side for a fixed period of time, e.g., 15 minutes.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence: 

		 Final Compliance report Evidence: 
x.	Status	Complied

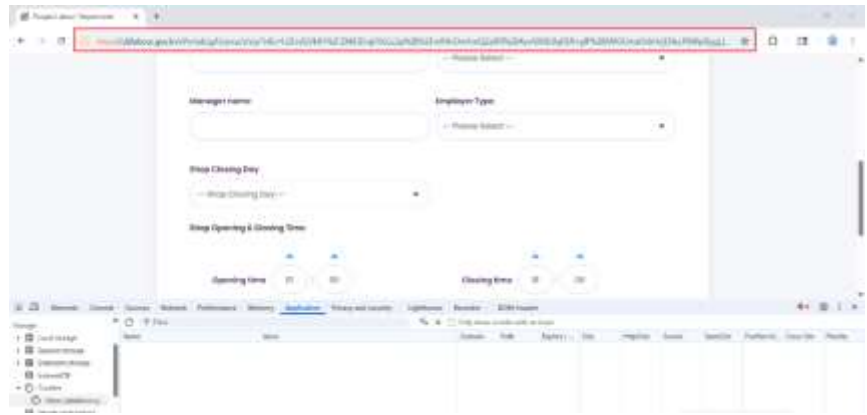
5)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Web Server Information Disclosure
iii.	Detailed Observation / Vulnerable Point	Banner grabbing (application is displaying Server version which may help attacker to learn more about his target) is possible in the application.
iv.	CVE / CWE	CWE-693
v.	Severity	Low
vi.	Recommendation	Server version should not be displayed to the end user.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

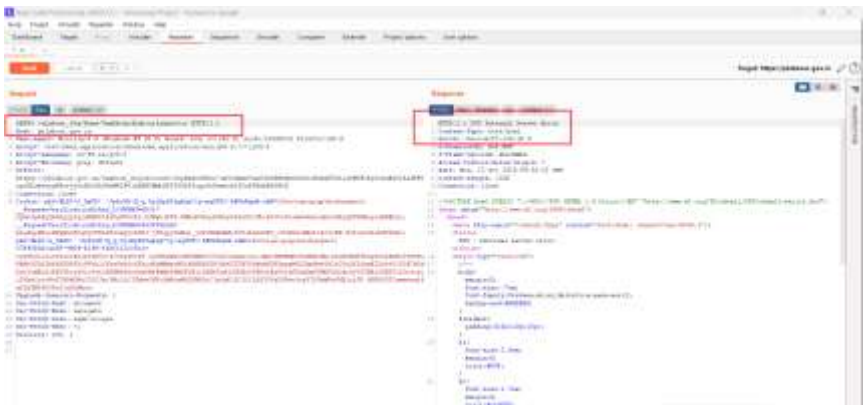
		
x.	Status	Complied

6)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Cookie without Same Site Attribute
iii.	Detailed Observation / Vulnerable Point	It is observed that cookie has been set without the Same Site attribute, which means that the cookie can be sent as a result of a 'cross-site' request
iv.	CVE / CWE	CWE-203
v.	Severity	Low
vi.	Recommendation	The server can set a same-site cookie by adding the SameSite=... attribute to the Set-Cookie header. There are three possible values for the SameSite attribute: • Lax: In this mode, the cookie will only be sent with a top-level get request. Set-Cookie: key=value; SameSite=Lax • Strict: In this mode, the cookie will not be sent with any cross-site usage even if the user follows a link to another website. Set-Cookie: key=value; SameSite=Strict • None: In this mode, the cookie will be sent with the cross-site requests. Cookies with SameSite=None must also specify the Secure attribute to transfer them via a secure context. Setting a SameSite=None cookie without the Secure attribute will be rejected by the browsers. Set-Cookie: key=value; SameSite=None; Secure
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:

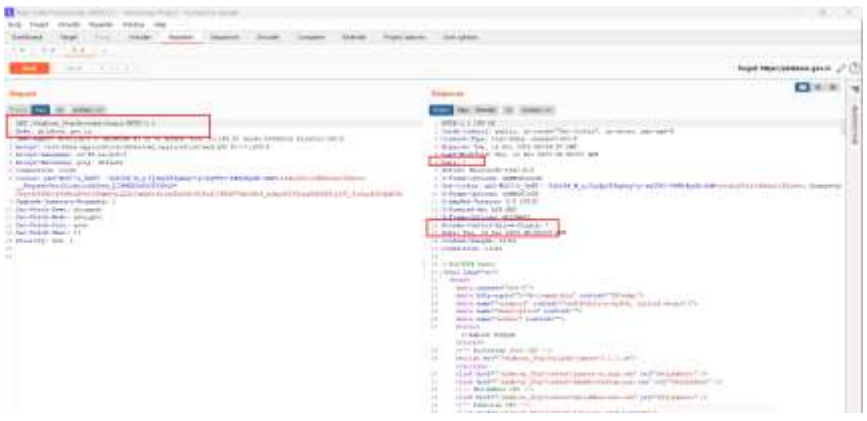
		 Final Compliance report Evidence: 
x.	Status	Complied

7)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Internal Server Error
iii.	Detailed Observation / Vulnerable Point	The server responded with an HTTP status 500, indicating there is a server side error.
iv.	CVE / CWE	CWE-20
v.	Severity	Medium
vi.	Recommendation	Analyse this issue and review the application code in order to handle unexpected errors; This should be a generic practice, which does not disclose further information upon an error. All errors should be handled server side only.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

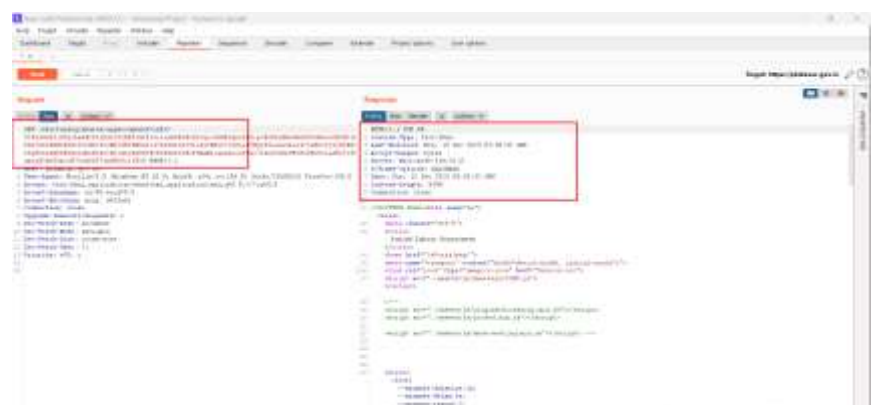
		
x.	Status	Closed

8)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Cross-Origin resource sharing misconfiguration
iii.	Detailed Observation / Vulnerable Point	It was observed that the CORS Cross Origin Resource Sharing Misconfiguration Lead to sensitive information.
iv.	CVE / CWE	CWE-693
v.	Severity	Low
vi.	Recommendation	Rather than using a wildcard or programmatically verifying supplied origins, use a whitelist of trusted domains.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

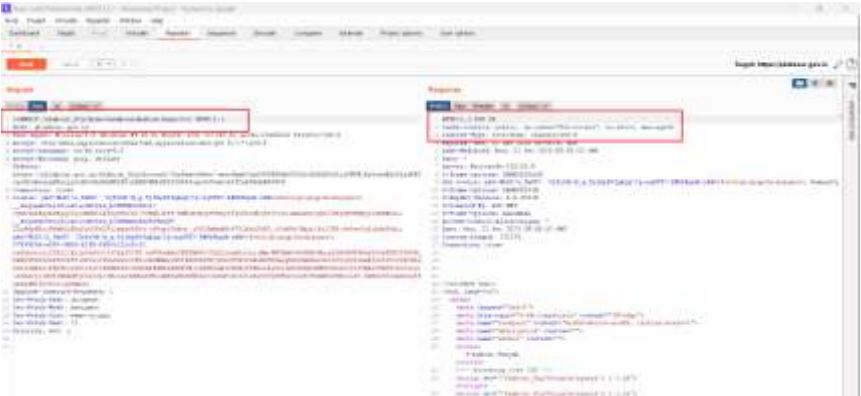
		
x.	Status	Complied

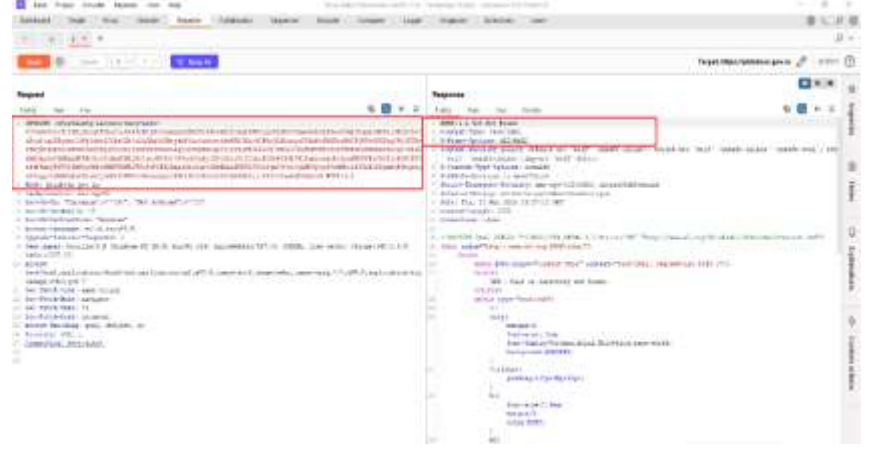
9)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	HTTP Security Headers Not Implemented
iii.	Detailed Observation / Vulnerable Point	It was observed that HTTP Security Headers were not implemented on the remote application.
iv.	CVE / CWE	CWE-1275
v.	Severity	Low
vi.	Recommendation	It is recommended to implement the following HTTP headers • X-XSS-Protection: 1; mode=block [2] • X-Content-Type-Options: no sniff • Content-Type: text/html; charset=utf-8 • Strict-Transport-Security: max-age=31536000; include Subdomains; preload • Content-security-policy: script-src'self' • Referrer-Policy: no-referrer same-origin origin strict-origin no-origin-when-downgrading Not Implemented
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

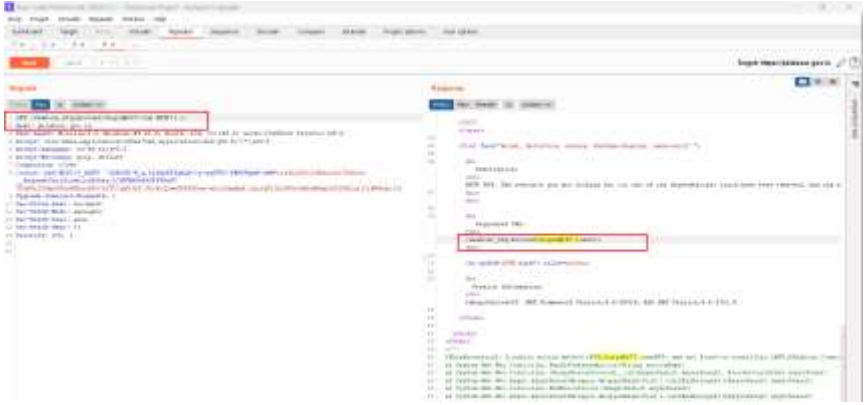
		
x.	Status	Complied

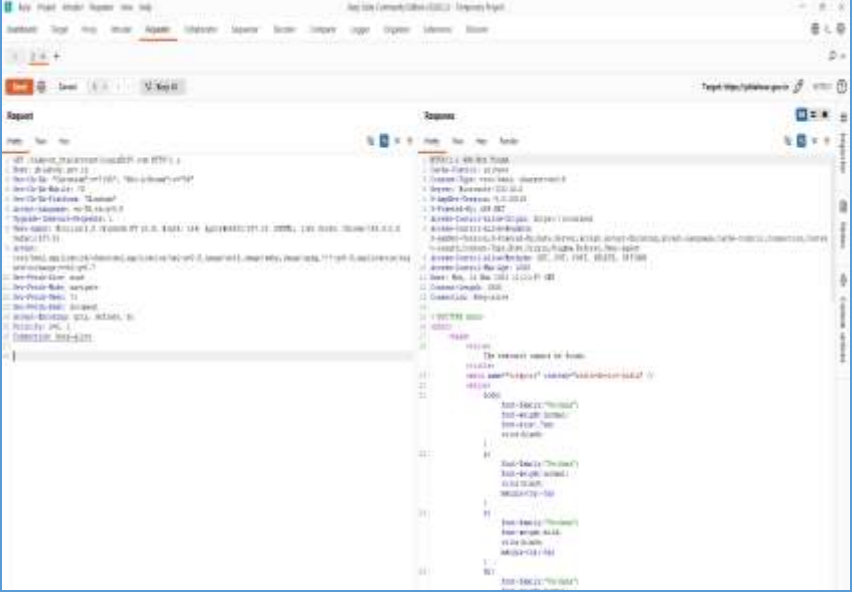
10)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	HTTP Dangerous Method Enabled
iii.	Detailed Observation / Vulnerable Point	It was observed that Http (Options,) method is enabled on this web server.
iv.	CVE / CWE	CWE-1275
v.	Severity	Low
vi.	Recommendation	It is recommended to disable http dangerous methods on the web server
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

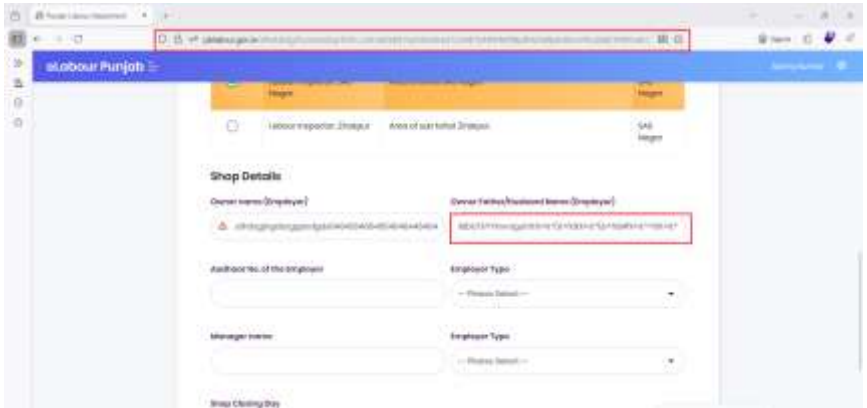
		
x.	Status	Complied

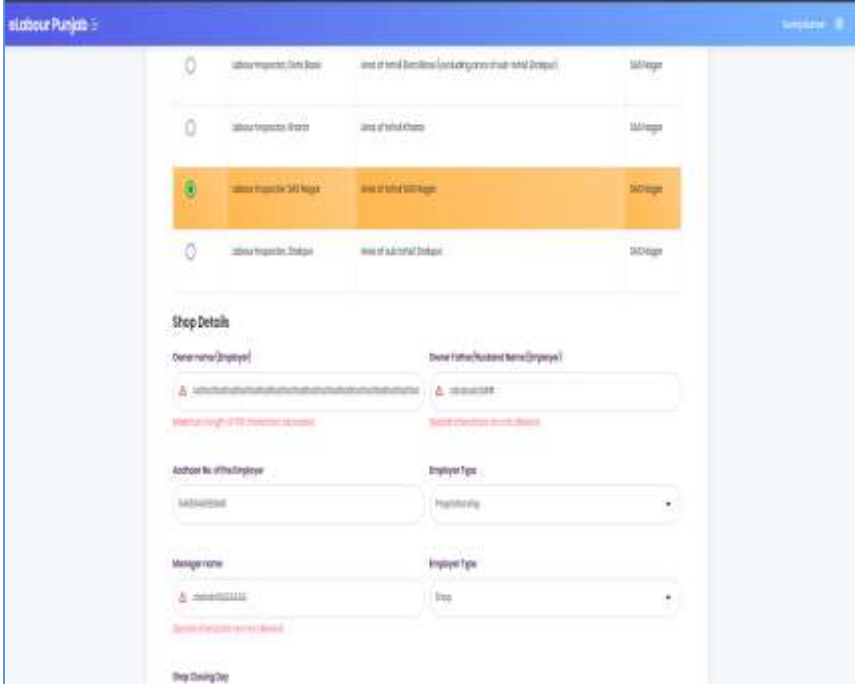
13)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Email Address Disclosure
iii.	Detailed Observation / Vulnerable Point	It was observed that an email address disclosure.
iv.	CVE / CWE	CWE-1275
v.	Severity	Low
vi.	Recommendation	Use generic email addresses such as contact@ or info@ for general Communications and remove user/people specific email addresses from the website; should this be required, use submission forms for this purpose.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

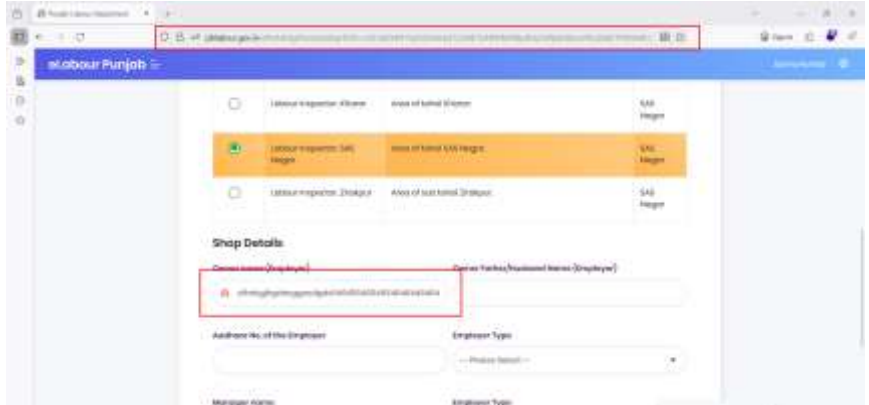
		
x.	Status	Complied

12)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Input Validation not implemented properly in the application
iii.	Detailed Observation / Vulnerable Point	It was observed that null parameter are passing to the server in the application
iv.	CVE / CWE	CWE-209
v.	Severity	Low
vi.	Recommendation	It is recommended that Username and Password fields should be validated at client and server end and it should not be null.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence:

		 The screenshot shows the 'Labour Punjab' website interface. At the top, there's a header with the logo and navigation links. Below the header, there's a table listing various shops. The third row is highlighted in orange. Below the table, there's a 'Shop Details' section with several input fields and dropdown menus for entering shop information.
x.	Status	Complied

13)

i.	Affected Asset i.e. IP/URL/Application etc	https://pblabour.gov.in/ePortalstg/
ii.	Observation / Vulnerability Title	Buffer overflow
iii.	Detailed Observation / Vulnerable Point	It was observed that max. Length for captcha fields is not defined.
iv.	CVE / CWE	CWE-1275
v.	Severity	Low
vi.	Recommendation	Length restrictions for every input field should be defined at client as well as at server end.
vii.	Reference	CERT-In Guidelines, OWASP
viii.	New or Repeat observation	New
ix.	References to evidences / Proof of Concept	Interim report Evidence:  Final Compliance report Evidence: 



x.	Status	Complied
----	--------	----------

9 Appendices

Glossary

AAA	AAA Technologies Limited
CERT-In	Indian Computer Emergency Response Team
CIS	Center for Internet Security
MeitY	Ministry of Electronics and Information Technology
OWASP	Open Worldwide Application Security Project